The Crypt O Plague

trimarcsecurity.com/hub-post/the-crypt-o-plague

Sean Burgess October 31, 2023

Updated: Dec 13, 2024

The following story is based on true events. The names, places, and realism have been changed to protect the identities of the living and undead. All the technical details of the story are accurate despite the ghoulish embellishment.

My name is Sean Burgess. I've spent a long time working in IT. Before I got into the security business, I was in the business of managed services. It was a messy world of mismanaged networks and clients who didn't know if they wanted it fixed, or just to complain when it wasn't. I'm here to tell you about one of the oddest cases I've had to deal with growing up in the world of downed servers and untrustworthy users.

A Bump In The Night

It was late Friday night, and I was up late to put out another fire. What I didn't know was that something terrible was eerily working its way through one of my strangest client's networks. While I was packing up and heading out the door, Cindy in accounting had awoken something unholy. She'd clicked on an email link from some homunculus pretending to be human resources. Ironic considering how unhuman they were. The link contained the CryptoLocker virus.

CryptoLocker is a piece of ransomware dreamed up by cocky cyber criminals. I'd always thought of these guys as necromancers leveraging undead botnets to infect unsuspecting victims. CryptoLocker was a real piece of work. It slowly encrypts all the files it can reach using the permissions granted to it by the unknowing victim. This means, the whole workstation and usually the file servers too. If you're really unlucky, it'll get the SYSVOL and NETLOGON directories as well. That requires some real messed up permissions though. Fortunately for me, I wasn't that unlucky, or so I thought…

Whistling Through The Graveyard

It was hard to get spookier than this client. They didn't monitor for changes in file encryption and had no FSRM (File Server Resource Manager), SIEM (Security Information Event Monitoring), or SOC (Security Operations Center). Consequently, my team didn't

hear word one about the issue until Monday morning. It was a bright and sunny morning, just the kind of day to be stuck in the office. Then again, I didn't realize how good I had it.

The client called in a panic. All their files had been entombed…uh…encrypted. Their antivirus was Dead On Arrival and hadn't tried to stop it at all. It turns out that this was a zero-day infection. This means that it was the first time this specific plague had been released on an unsuspecting victim or at least not often enough to be in the antivirus definitions yet.

The infection was so bad that we had to go onsite to assess the damage. I'd started working with this client a few weeks prior to this whole incident, and I had never been there. I was just the guy keeping the lights on from the shadows. My boss hadn't told me how odd this one was until I got there. A few gentlemen from my team had joined me on this little adventure. Nam, Ken, and Marcus. Nam was the only one of us who'd been there before.

It was a literal village in the middle of a haunted forest. Hansel and Gretel wouldn't have come within a mile of this place. I wasn't aware of any haunted forests in the suburbs of Washington, D.C., but then again, it made sense with all the buried skeletons in that area. Like most remote villages in any old story, it had a Data Center. I wanted to point out the missed opportunity for using "Server FARM" but Nam didn't seem like he was in the mood.

I decided my questions regarding the peculiarity of the client could be investigated later. My team and I started by meeting with the guy in charge of local IT operations at this site. His office was at the main building in town at the corner of Vincent and Price. I looked at Nam questioningly and he said it was an inside joke. Office workers shuffled around him with pale skin and a dead sunken look in their eyes. "Zombies?" I asked. "No, they're always like that on Mondays" he said.



He doesn't get many Helldesk tickets.

We went to his office, and he sat at his desk. He had two workstations; one was his standard machine and the other was his PAW (Privileged Access Workstation). I was surprised he'd implemented PAWs in an environment like this, but then again, he was a werewolf. We went over the status of the infection and came up with some action items.

For now, the plan was to get everything back up and running as quickly as possible. This meant figuring out which machines were infected, re-imaging them, then restoring the encrypted files. Normally we would have already known which machines were infected but CryptoLocker had gone completely undetected by any of the substandard tools keeping this place running. The easiest sign was if the computer files had been encrypted.

Logs From The Crypt

CryptoLocker was insidious though. It didn't encrypt the files of every infected machine. Some computers acted as sleeper agents, reinfecting any machine they could reach while keeping their own files clean. Normally I would have just reimaged all of the workstations and the infected file servers but the client only had one server for re-imaging workstations

and it was slow. Ironically, it used an older version of Ghost to get the job done. Seeing as these workstations might as well have been dead, it made sense.



We had to find a way to quickly and definitively determine which computers had been infected. Fortunately, I'd been using an old antivirus tool that has since been laid to rest called ComboFix. This was great for removing viruses - if you didn't mind it roughing up your computer a little bit. The program was not delicate when removing files. I didn't care if it was successful or not in removing the virus. What I wanted was the log file that it spit out at the end of the process. ComboFix dropped a complete list of all of the files that it had removed, and I was willing to bet that it would find at least part of the infection. ComboFix didn't simply look for viruses using just a standard list of known definitions, It also looked for unusual system and program files removing them as well. You did not want to run this software on any machine where you had been making manual changes.

My test was successful. The tool had discovered bits of the virus and upon later testing, could reliably identify which computers had been infected. I used a Group Policy to deploy and scan each computer on the network using ComboFix via command script and copy the logs to a single test machine. ComboFix was an executable that didn't need to be installed. This made the process quicker. Each log file contained the name of the computer it had

run on and the status of the infection. Unfortunately, not every computer responded, and we still had to wander around the village manually scanning about a third of the computers.

This village was a nightmare with streets not even Freddy would walk down. Most of the village people broke into uncontrolled hysterical screaming at random intervals and then returned to their business like nothing happened. Their eyes stared off into space as they milled about. Or for anyone who has ever worked in a finance, a Tuesday.

My nerves were shot after days of manually scanning every machine in the network. Malcolm the operations werewolf had his team helping us throughout the process, but I wasn't confident with the work his team was doing based on the vacant look on their ghoulish looking faces. It turned out they couldn't read the logs they were getting; they'd just marked every computer they scanned as infected. Nam, Kevin, Marcus and I had to backtrack all their work.

After several days of hard work, we were able to find every infected computer and reimage them all. We restored the file servers from backups and begun the process of cleaning up our work areas. One of my team at headquarters was assigned to keep an eye on the network in case CrytoLocker started to spread its ugly tendrils through the file servers again. I was still trying to convince the witch who ran this village to spend a little money on upgrading the security. I'm not being mean; she was a literal witch. That's a whole different story though. Before Esmeralda the witch could tell me she "didn't have the budget for security", my guy from headquarters called with panic in his voice.

Necromancy

The network had been reinfected, but it was worse than the first time. I was too exhausted to be shocked or angry. I was still curious though. He told me that the infection had reached the Domain Controllers this time. "How could this have happened?" I breathed while barely able to believe my bad luck. He told me that the infection appeared to be using Malcolm's Domain Admin credentials. At first, I was dumbfounded but then I remembered that big werewolf's PAW. Not the furry ones, the supposedly secure ones. I went back to his office and found the big mutt sitting at his desk with a USB drive plugged directly into his PAW. I was incredulous. How could the guy who runs the whole town's IT be so foolish? Well, it turned out the witch liked the guy because he was big and loyal. She didn't really care that he was also a bit **dumb**.

The second cleanup process took nearly as long as the first. We used our backup system to restore all the Domain Controllers simultaneously. Then after shutting down every infected workstation (including the PAW), we restored the file servers. We then got around to the arduous business of Ghosting every workstation in the network. We didn't need to

figure out which ones had been infected this time since they all had been. The whole process from start to finish took two weeks. Needless to say, I was sick of that client by the time we ventured home.

The witch Esmeralda decided not only was she not going to spend more money on upgrading the security for her village, but she was also going to find another service provider that was cheaper. She cast a spell (also known as “hiring a couple of shady characters in a van”) to come in after us and remove all our remote access tools. I wasn’t too mad about it though. I knew she’d be back someday. Such is the life cycle of odd clients. They hire the best, everything gets fixed, and then they hire some cheap rando who breaks everything only for the client to have to hire the best again. She’d be back, I just hoped it wouldn’t be too soon…

Post Mortem

I learned a few lessons from this nightmare incident:

1. The PAW should have had a policy in place to prevent USB storage devices from running.

2. The file servers should have had FSRM policies in place to block unknown encryption file extensions and to generate alerts for unusual file activity.

3. The file share size and permissions should have been more limited to reduce the scope of the infection.

4. There should have been a SIEM in place to capture aggregated logs.

5. Don’t hire big dumb werewolves to manage your network.


Sequels are a disease. Meet the cure.
ANOTHER
WOLFCOP
The hairy arm of the law.
The Dude Designs
DALVA
DALVA